

IAM & Access Governance Plan

RBAC, MFA, privileged access, joiner/mover/leaver, service accounts, and access review

Control	Standard	Owner	Evidence	90-day target
MFA	Required for privileged and remote access; stronger factors for admins	IAM	IdP policy + enrollment report	100% privileged
RBAC	Access mapped to job function and least privilege	System / Data Owners	Role matrix + approvals	High-risk systems documented
Joiner	Manager-approved role-based access	HR / IAM	Ticket + approval + directory state	100% sampled joiners
Mover	Remove obsolete rights before/with new access	Manager / IAM	Before/after entitlement review	100% sampled movers
Leaver	Prompt disable, token/session revocation, shared-secret review	HR / IAM	Termination time + disable log	Within policy target
Privileged review	Quarterly recertification	IAM / Security	Group export + attestation + removal tickets	100% critical groups
Service accounts	Named owner, purpose, least privilege, secret rotation	App Owner	Inventory + usage + rotation	100% critical service accounts
Third-party access	Sponsor, expiry, SSO/MFA, periodic review	Vendor Owner	Sponsor + expiry + review	100% high-risk vendors

Access Escalation Triggers

- Orphan or ownerless privileged/service account.
- Privilege inconsistent with role.
- Third-party account without expiration or sponsor.
- Admin login without strong MFA.
- Account remains active after separation.
- Repeated failed access review or unremediated excess permissions.